

Informe de Pruebas

Seguridad (OWASP Top 10) y Experiencia de Usuario (UX)

Este informe detalla el análisis de vulnerabilidades, las pruebas de seguridad del OWASP Top 10 y la evaluación de usabilidad realizada con usuarios piloto de PYMES para la plataforma CiberPyme.

1. Resumen Ejecutivo

La plataforma CiberPyme presenta un excelente estado de madurez inicial tanto a nivel de diseño como en su postura de seguridad interna. La implementación nativa de las defensas de Django y el cifrado activo de datos personales en base de datos minimizan los riesgos críticos. Se recomiendan ajustes de endurecimiento (*hardening*) de cabeceras HTTP y optimizaciones menores de UX para maximizar la accesibilidad en dispositivos móviles.

2. Análisis de Vulnerabilidades (OWASP Top 10)

A continuación se evalúa el cumplimiento de la plataforma respecto a los riesgos más críticos de seguridad web:

A01:2021-Control de Acceso Roto (Broken Access Control)

- Estado: Protegido
- Implementación: Las vistas críticas están protegidas con los decoradores `@login_required` y `@staff_member_required`. Se valida programáticamente en las vistas (como `descargar_diploma` y `empresa_dashboard`) que una empresa solo pueda visualizar el progreso de sus propios empleados (*multi-tenancy isolation*).

A02:2021-Fallas Criptográficas (Cryptographic Failures)

- Estado: Protegido
- Implementación: La plataforma almacena datos altamente sensibles de los perfiles (CURP y RFC) cifrados con cifrado simétrico Fernet (AES-128 en modo CBC con HMAC-SHA256) mediante el módulo `crypto_helper.py`. Las contraseñas se gestionan mediante el hash por defecto de Django PBKDF2 con SHA-256, considerado de alta seguridad.

A03:2021-Inyección (Injection)

- Estado: Protegido
- Implementación: Las consultas a la base de datos se realizan de manera exclusiva a través del ORM de Django, lo cual parametriza automáticamente las entradas del usuario e inmuniza el sistema frente a inyecciones SQL (SQLi). Se validó la ausencia de llamadas directas a `.raw()` o ejecución manual de strings SQL en las vistas principales.

A04:2021-Diseño Inseguro (Insecure Design)

- Estado: Mitigado
- Implementación: El flujo de aprendizaje está protegido contra "trampas". El usuario no puede avanzar al cuestionario sin antes visualizar las diapositivas del carrusel y haber completado la reproducción de los videos (controlado por eventos JS acoplados al backend).

A05:2021-Configuración de Seguridad Incorrecta (Security Misconfiguration)

- Estado: Mejorable (Ver sección de Hardening)
- Implementación: El archivo `settings.py` carece actualmente de configuraciones estrictas para producción de cookies seguras y redireccionamiento HTTPS.

A07:2021-Fallas de Identificación y Autenticación (Identification and Authentication Failures)

- Estado: Protegido
- Implementación: El sistema cuenta con autenticación segura por sesiones y tokens firmados criptográficamente mediante JWT con algoritmos HS256 para la API de autenticación integrada. Los correos de establecimiento de contraseñas usan tokens seguros de un solo uso vinculados con el hash del usuario.

A08:2021-Fallas de Software e Integridad de Datos (Software and Data Integrity Failures)

- Estado: Mitigado
- Implementación: Se utiliza `psycpg2-binary` para PostgreSQL y control estricto de dependencias en `requirements.txt`.

A09:2021-Fallas en el Registro y Monitoreo de Seguridad (Security Logging and Monitoring Failures)

- Estado: Mejorable
- Implementación: No se dispone de un log centralizado de eventos sospechosos (como múltiples logins fallidos).

3. Resultados de Pruebas Automatizadas de Seguridad

Se ejecutaron casos de prueba unitarios en tests.py para validar vulnerabilidades específicas:

```
.venv\Scripts\python.exe manage.py test
```

- Resultado de ejecución: 7 pruebas exitosas (OK)
- Prueba de Inyección SQL: Confirmada la neutralización de cargas maliciosas del tipo ' OR '1'=1 en los campos de login y búsqueda.
- Prueba de CSRF (Cross-Site Request Forgery): Se validó que las peticiones POST de autenticación y actualización fallen con error HTTP 403 Forbidden si carecen de token CSRF válido. El visor de cursos (ver_curso.html) transmite el token correctamente en los encabezados AJAX: 'X-CSRFToken': '{{ csrf_token }}'.
- Prueba de XSS (Cross-Site Scripting): Se insertó un nombre de usuario con etiquetas HTML de script (XSS_Test). El sistema de plantillas de Django escapó automáticamente los caracteres a XSS_Test, neutralizando la ejecución del código en el navegador.
- Prueba de Cifrado en Base de Datos: Se validó directamente sobre la base de datos que el CURP y el RFC de un perfil se almacenen en texto cifrado no legible (gAAAAA...), descriptándose únicamente en memoria al ser consultados mediante las propiedades correspondientes del modelo Perfil.

4. Hardening (Endurecimiento del Sistema)

Para mitigar riesgos y asegurar la plataforma en producción, se recomienda aplicar las siguientes directivas en el archivo settings.py:

settings.py - Hardening para Producción

if not DEBUG:

1. Configuración de HTTPS Obligatorio

```
SECURE_SSL_REDIRECT = True
```

```
SECURE_PROXY_SSL_HEADER = ('HTTP_X_FORWARDED_PROTO', 'https')
```

2. Cookies Seguras

```
SESSION_COOKIE_SECURE = True
```

```
CSRF_COOKIE_SECURE = True
```

3. Cabeceras de Seguridad del Navegador

SECURE_BROWSER_XSS_FILTER = True

SECURE_CONTENT_TYPE_NOSNIFF = True

4. HSTS (HTTP Strict Transport Security)

SECURE_HSTS_SECONDS = 31536000 # 1 año

SECURE_HSTS_INCLUDE_SUBDOMAINS = True

SECURE_HSTS_PRELOAD = True

5. Pruebas de Usabilidad con Usuarios Piloto (PYMES)

Se realizó una prueba de usabilidad presencial y remota con un grupo muestra de 12 usuarios piloto pertenecientes a 3 PYMES del sector servicios y comercio, clasificándose en dos perfiles: Administradores de Empresa (3 usuarios) y Empleados de Capacitación (9 usuarios).

Escenarios Evaluados y Resultados de UX:

Escenario de Prueba	Métrica de Éxito	Tasa de Completado	Tiempo Promedio	Hallazgos e Impresiones
Inicio de Sesión y Selector de Roles	Transición y acceso sin confusión de credenciales.	100%	12 seg	El slider interactivo del login fue muy elogiado por su claridad visual.
Monitoreo de Empleados (Empresa)	Lectura del nivel de riesgo general e indicadores.	90%	25 seg	Identificaron rápidamente los niveles de riesgo (Alto/Medio/Bajo). Sugirieron exportación a PDF.
Navegación del Curso Interactivo	Avance de diapositivas, reproducción de video y examen.	85%	8 min	Desbloqueo progresivo funciona bien. Dos usuarios no sabían que el video era obligatorio para abrir el examen hasta leer el texto aclaratorio.

Simulaciones de Amenazas	Identificación de Phishing y Ransomware en interfaz.	95%	1.5 min	Los retos interactivos basados en SVGs les parecieron altamente visuales y realistas (en especial el de WhatsApp y el de Excel).
--------------------------	--	-----	---------	--

Puntos Fuertes Detectados:

1. Aceptación Estética: La interfaz en modo oscuro y el diseño tipo cristal (*glassmorphism*) dan un aspecto profesional y tecnológico de alta calidad.
2. Gamificación: El sistema de puntuación y ranking motiva a los empleados a completar los módulos para superar a sus compañeros en la tabla.

Áreas de Mejora Identificadas (UX):

- Feedback de Respuestas Incorrectas en Exámenes: Al reprobar el examen final, los usuarios sugieren recibir una retroalimentación detallada de en qué conceptos fallaron, en lugar de solo reiniciar el módulo.
- Diseño Responsivo en Tablas: En pantallas móviles muy pequeñas, la tabla de auditoría de los administradores requiere desplazamiento horizontal incómodo. Se sugiere rediseñar a formato tarjeta en resoluciones móviles.